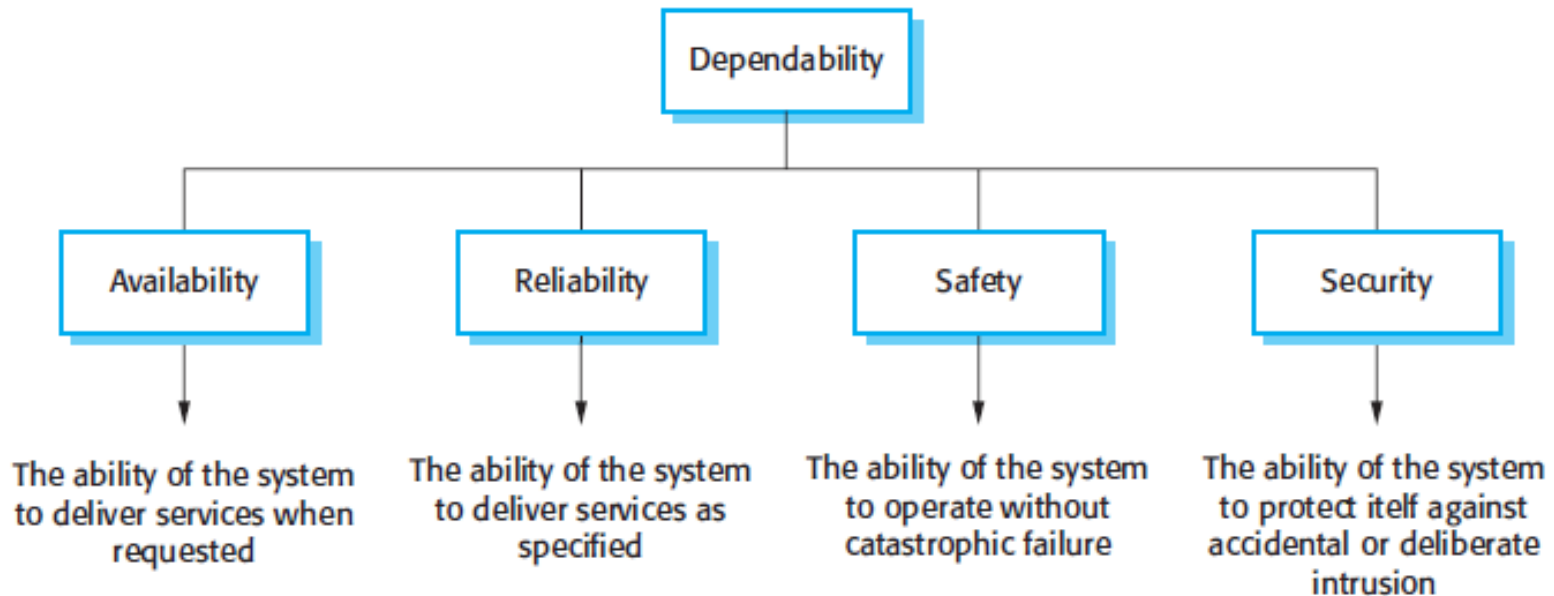


Dependable systems

System dependability

- The most important system property is the **dependability** of the system.
- The **dependability** of a system reflects the **user's degree** of **trust** in that system.
- It reflects the extent of the user's **confidence** that it will operate as users expect and that it will not '**fail**' in **normal** use.
- Dependability covers the related systems attributes of **reliability**, **availability** and **security**.

Principal dependability properties



Principal properties

- Availability
 - The probability that the system will be up and running and able to deliver useful services to users.
- Reliability
 - The probability that the system will correctly deliver services as expected by users.
- Safety
 - A judgment of how likely it is that the system will cause damage to people or its environment.
- Security
 - A judgment of how likely it is that the system **can resist accidental or deliberate intrusions.**

Dependability attribute dependencies

- Safe system operation depends on the system being available and operating reliably.
- A system may be unreliable because its data has been corrupted by an external attack.
- Denial of service attacks on a system are intended to make it unavailable.
- If a system is infected with a virus, you cannot be confident in its reliability or safety.

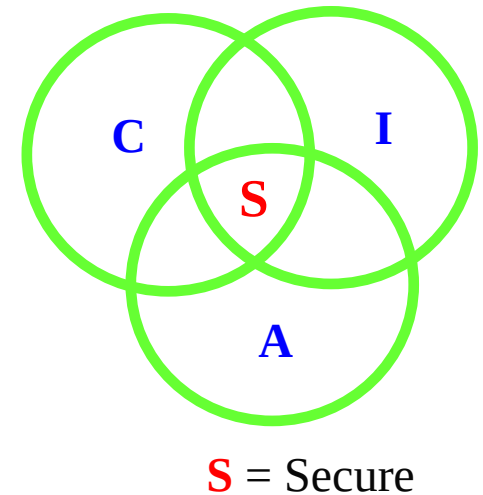
Security

Security

- The security of a system is a system property that reflects the system's **ability to protect itself from external attacks** which may be **accidental or deliberate**.
- Security is essential as most systems are **networked** so that external access to the system through the **Internet** is possible.
- Security is an essential pre-requisite for **availability, reliability** and **safety**.

Security Objectives: CIA

- **Confidentiality (or secrecy)**
 - unauthorized users cannot read information
- **Integrity**
 - unauthorized users cannot alter information
- **Availability**
 - authorized users can always access information



Security Objectives: CIA

- **Confidentiality**

- Information in a system may be **disclosed** or made **accessible** to people or programs that are not **authorized** to have access to that information. **For example, the theft of credit card data from an e-commerce system is a confidentiality problem.**

- **Integrity**

- Information in a system may be **damaged** or **corrupted** making it unusual or unreliable. **For example, a worm that deletes data in a system is an integrity problem.**

- **Availability**

- Access to a system or its data that is normally **available** may not be **possible**. **A denial-of-service attack that overloads a server is an example of a situation where the system availability is compromised.**

Malicious software

Malicious software, commonly known as **malware**, is any software that brings **harm to a computer system**.

- Worm
- Virus
- Trojan Horse

Tools for Confidentiality

- **Encryption**: the transformation of information using a secret, called an encryption key, so that the transformed information can only be read using another secret, called the decryption key (which may, in some cases, be the same as the encryption key).
- **Plaintext** : Data input to the Cipher or output from the Inverse Cipher.
- **Ciphertext/Cipher Text** : Data in its encrypted form.

Tools for Confidentiality

- **Authentication:** the determination of the identity or role that someone has.
- This determination can be done in a number of different ways, but it is usually based on a combination of
 - ❑ something the person has (like a smart card)
 - ❑ something the person knows (like a password),
 - ❑ something the person is (like a human with a fingerprint).

Security terminology

- **Asset** الأصول
 - Something of **value** which has to be **protected**. It may be the software system itself or data used by that system.
- **Vulnerability** نقاط الضعف
 - A weakness in a computer-based that may be exploited to cause loss or harm..
- **Attack**
 - An **exploitation** of a system's vulnerability. Generally, this is from **outside the system** and is a **deliberate attempt** to cause some damage.

Security terminology

- **Threat**

- Circumstances that have potential to cause loss or harm. You can think of these as a system vulnerability that is subjected to an attack.

- **Exposure**

- Possible loss or harm to a computing system. This can be loss or damage to data or can be a loss of time and effort if recovery is necessary after a security breach.

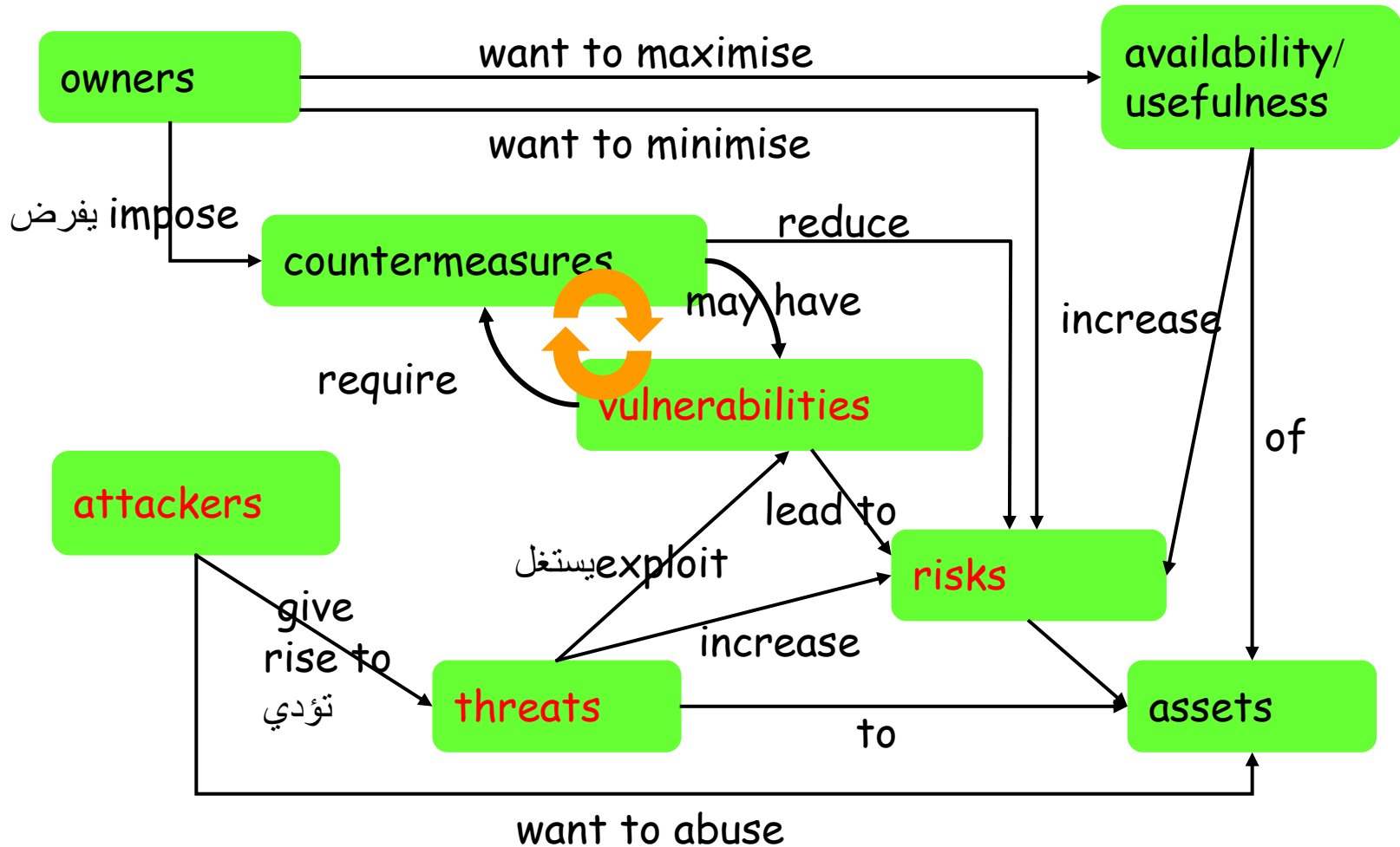
- **Control (countermeasures) التدابير الوقائي يقلل من ضعف النظام**

- A protective measure that reduces a system's vulnerability. **Encryption** is an example of a control that reduces a vulnerability of a weak access control system

Examples of security terminology (MHC-PMS)

Term	Example
Asset	The records of each patient that is receiving or has received treatment.
Exposure	Potential financial loss from future patients who do not seek treatment because they do not trust the clinic to maintain their data. Loss of reputation.
Vulnerability	A weak password system which makes it easy for users to set guessable passwords . User ids that are the same as names.
Attack	An impersonation of an authorized user.
Threat	An unauthorized user will gain access to the system by guessing the credentials (login name and password) of an authorized user.
Control	A password checking system that disallows user passwords that are proper names or words that are normally included in a dictionary.

Security concepts [as used in Common Criteria]



Threat types

- A threat:
 - is a danger which could affect the security (confidentiality, integrity, availability) of assets, leading to a potential loss or damage.
- Threats are being in four types:
 - Interception
 - Interruption
 - Modification
 - Fabrication

Threat types

- Interception threats that allow an attacker to gain access to an asset.
 - A possible threat to the Mentcare system might be a situation where an attacker gains access to the records of an individual patient.
- Interruption threats that allow an attacker to make part of the system unavailable.
 - A possible threat might be a denial of service attack on a system database server so that database connections become impossible.

Threat types

- **Modification threats** that allow an attacker to **tamper** with a system asset.
 - In the Mentcare system, a modification threat would be where an attacker **alters or destroys a patient record**.
- **Fabrication threats** that allow an attacker to insert **false** information into a system.
 - This is perhaps not a credible threat in the Mentcare system but would be **a threat in a banking system**, where false transactions might be added to the system that transfer money to the perpetrator's bank account.

Damage from insecurity

- **Denial of service**

- The system is forced into a state where normal services are unavailable or where service provision is significantly degraded

- **Corruption of programs or data**

- The programs or data in the system may be modified in an unauthorised way

- **Disclosure of confidential information**

- Information that is managed by the system may be exposed to people who are not authorised to read or use that information

Security and dependability

- **Security and reliability**

- If a system is attacked and the system or its data are corrupted as a consequence of that attack, then this may induce system failures that compromise the reliability of the system.

- **Security and availability**

- A common attack on a web-based system is a denial of service attack, where a web server is flooded with service requests from a range of different sources. The aim of this attack is to make the system unavailable.

Security and organizations

Security is a business issue

- Security is **expensive** and it is important that security decisions are made in a cost-effective way
 - There is no point in spending **more than the value of an asset to keep that asset secure.**
- Organizations use **a risk-based approach to support security decision making** and should have **a defined security policy based on security risk analysis**
- Security risk analysis is a business rather than a technical process

Organizational security policies

- Security policies should set out general information access strategies that should apply across the organization.
- The point of security policies is to inform everyone in an organization about security so these should not be long and detailed technical documents.
- From a security engineering perspective, the security policy defines, in broad terms, the security goals of the organization.
- The security engineering process is concerned with implementing these goals.

Security policies

- The assets that must be protected
 - It is not cost-effective to apply stringent security procedures to all organizational assets. Many assets are not confidential and can be made freely available.
- The level of protection that is required for different types of asset
 - For sensitive personal information, a high level of security is required; for other information, the consequences of loss may be minor so a lower level of security is adequate.

Security policies

- The responsibilities of individual users, managers and the organization
 - The security policy should set out what is expected of users e.g. strong passwords, log out of computers, office security, etc.
- Existing security procedures and technologies that should be maintained
 - For reasons of practicality and cost, it may be essential to continue to use existing approaches to security even where these have known limitations.

Security risk assessment and management

- Risk assessment and management is concerned with assessing the possible losses that might ensue from attacks on the system and balancing these losses against the costs of security procedures that may reduce these losses.
- Risk management should be driven by an organisational security policy.
- Risk management involves
 - Preliminary risk assessment
 - Life cycle risk assessment
 - Operational risk assessment

Preliminary risk assessment

- The aim of this initial risk assessment is to identify **generic risks** that are applicable to the system and to decide if an adequate level of security can be achieved at a reasonable cost.
- The risk assessment should focus on the identification and analysis of high-level risks to the system.
- The outcomes of the risk assessment process are used to **help identify security requirements**.

Security requirements

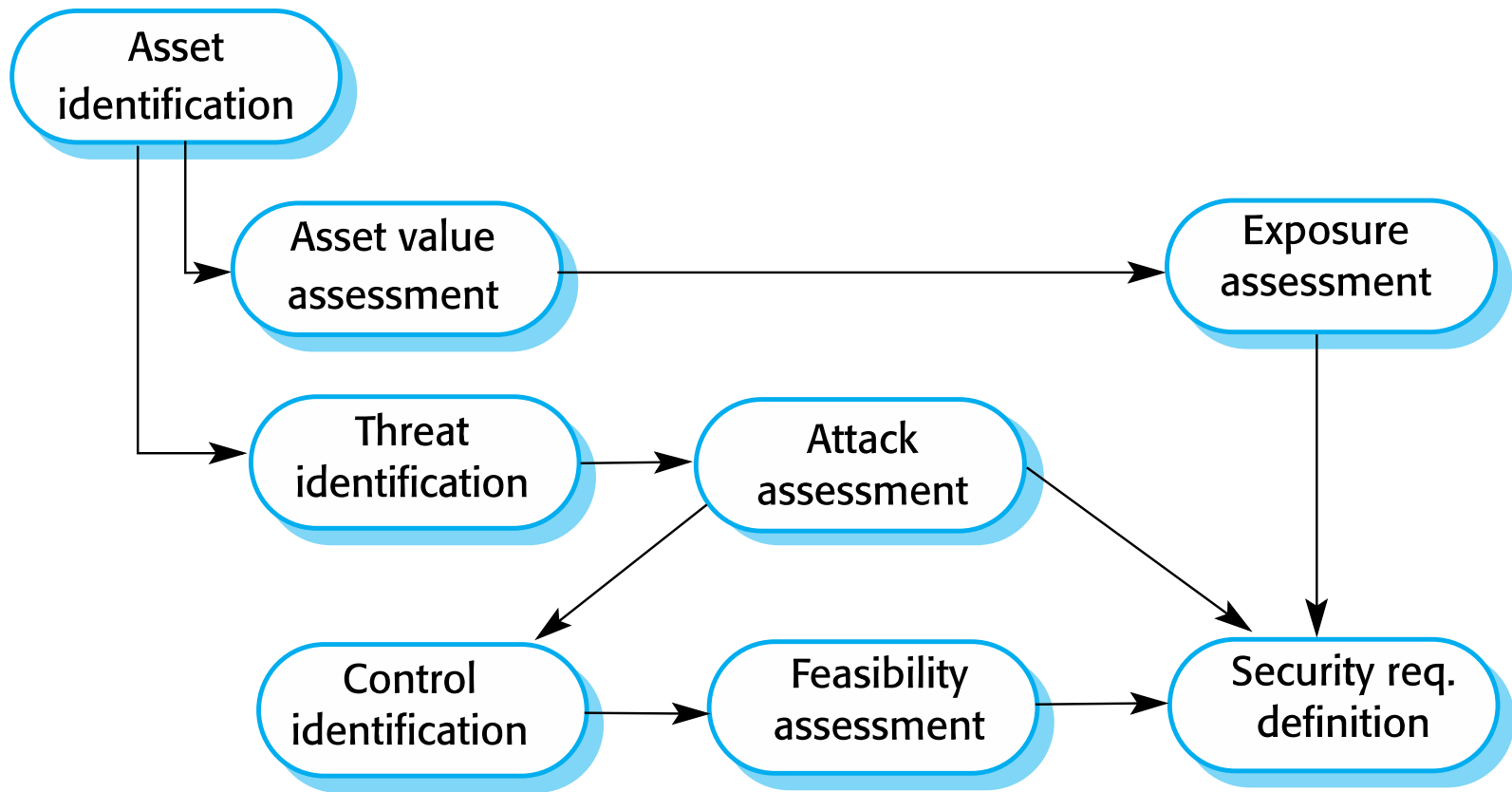
Types of security requirement

- **Identification requirements** specify whether or not a system should identify its users before interacting with them.
- **Authentication requirements** specify how users are identified.
- **Authorization requirements** specify the privileges and access permissions of identified users.
- **Immunity requirements** specify how a system should protect itself against viruses, worms, and similar threats.
- **Integrity requirements** specify how data corruption can be avoided.

Types of security requirement

- **Intrusion detection** requirements specify what mechanisms should be used to detect attacks on the system.
- **Non-repudiation requirements** specify that a party in a transaction cannot deny its involvement in that transaction.
- **Privacy requirements** specify how data privacy is to be maintained.

The preliminary risk assessment process for security requirements



Security risk assessment

- **Asset identification**

- Identify the key system assets (or services) that have to be protected.

- **Asset value assessment**

- Estimate the value of the identified assets.

- **Exposure assessment**

- Assess the potential losses associated with each asset.

- **Threat identification**

- Identify the most probable threats to the system assets

Security risk assessment

- **Attack assessment**

- Decompose threats into possible attacks on the system and the ways that these may occur.

- **Control identification**

- Propose the controls that may be put in place to protect an asset.

- **Feasibility assessment**

- Assess the technical feasibility and cost of the controls.

- **Security requirements definition**

- Define system security requirements. These can be infrastructure or application system requirements.

Asset analysis in a preliminary risk assessment report for the Mentcare system

Asset	Value	Exposure
The information system	High. Required to support all clinical consultations. Potentially safety-critical.	High. Financial loss as clinics may have to be cancelled. Costs of restoring system. Possible patient harm if treatment cannot be prescribed.
The patient database	High. Required to support all clinical consultations. Potentially safety-critical.	High. Financial loss as clinics may have to be cancelled. Costs of restoring system. Possible patient harm if treatment cannot be prescribed.
An individual patient record	Normally low although may be high for specific high-profile patients.	Low direct losses but possible loss of reputation.

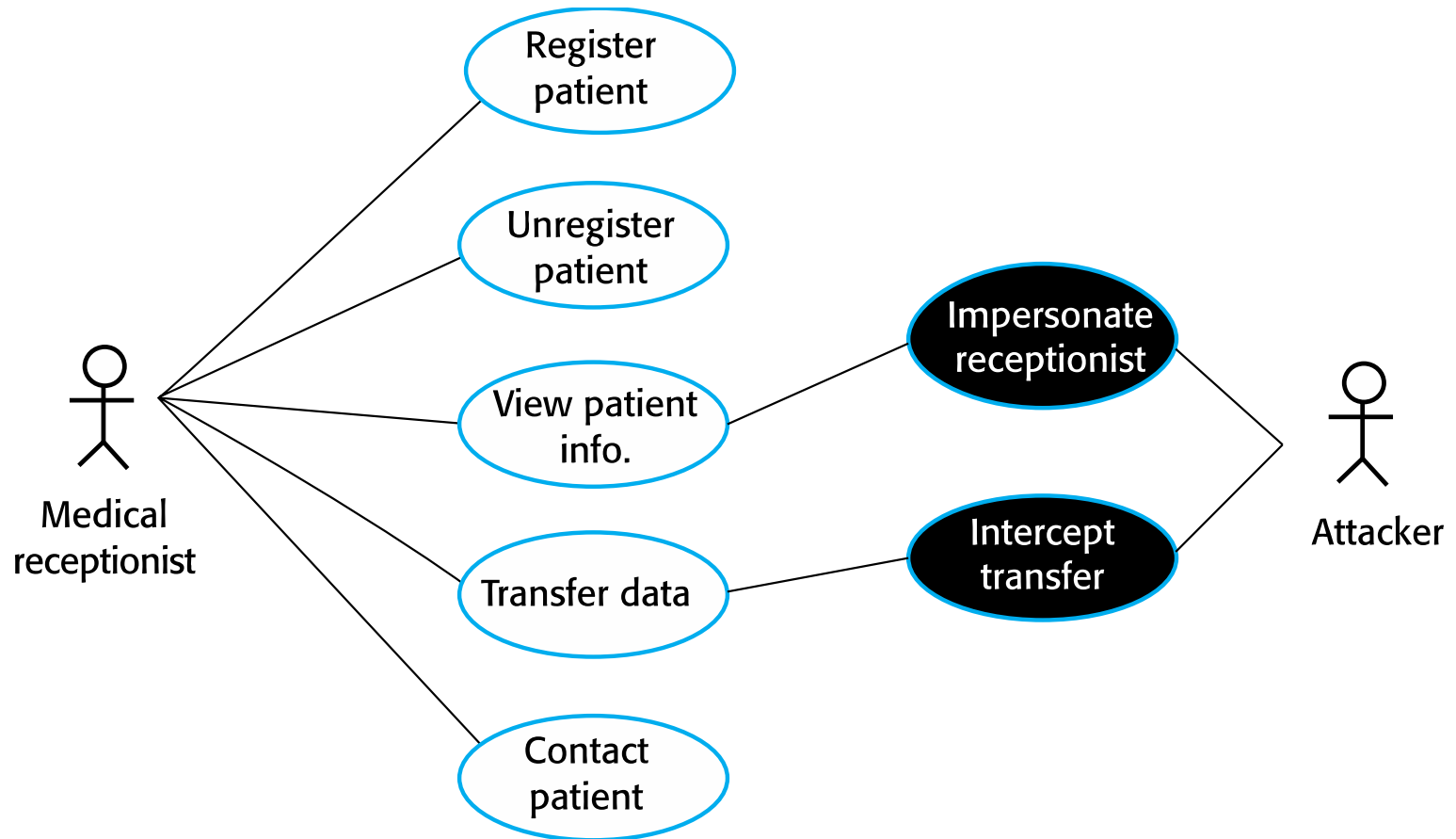
Threat and control analysis in a preliminary risk assessment report

Threat	Probability	Control	Feasibility
An unauthorized user gains access as system manager and makes system unavailable	Low	Only allow system management from specific locations that are physically secure.	Low cost of implementation but care must be taken with key distribution and to ensure that keys are available in the event of an emergency.
An unauthorized user gains access as system user and accesses confidential information	High	Require all users to authenticate themselves using a biometric mechanism. Log all changes to patient information to track system usage.	Technically feasible but high-cost solution. Possible user resistance. Simple and transparent to implement and also supports recovery.

Misuse cases

- Misuse cases are instances of threats to a system
- Interception threats
 - Attacker gains access to an asset
- Interruption threats
 - Attacker makes part of a system unavailable
- Modification threats
 - A system asset is tampered with
- Fabrication threats
 - False information is added to a system

Misuse cases



Mentcare use case – Transfer data

Mentcare system: Transfer data

Actors	Medical receptionist, Patient records system (PRS)
Description	A receptionist may transfer data from the Mentcare system to a general patient record database that is maintained by a health authority. The information transferred may either be updated personal information (address, phone number, etc.) or a summary of the patient's diagnosis and treatment.
Data	Patient's personal information, treatment summary.
Stimulus	User command issued by medical receptionist.
Response	Confirmation that PRS has been updated.
Comments	The receptionist must have appropriate security permissions to access the patient information and the PRS.

Mentcare misuse case: Intercept transfer

Mentcare system: Intercept transfer (Misuse case)

Actors	Medical receptionist, Patient records system (PRS), Attacker
Description	A receptionist transfers data from his or her PC to the Mentcare system on the server. An attacker intercepts the data transfer and takes a copy of that data.
Data (assets)	Patient's personal information, treatment summary
Attacks	A network monitor is added to the system and packets from the receptionist to the server are intercepted. A spoof server is set up between the receptionist and the database server so that receptionist believes they are interacting with the real system.

Misuse case: Intercept transfer

Mentcare system: Intercept transfer (Misuse case)

Mitigations	All networking equipment must be maintained in a locked room. Engineers accessing the equipment must be accredited. All data transfers between the client and server must be encrypted. Certificate-based client-server communication must be used
Requirements	All communications between the client and the server must use the Secure Socket Layer (SSL). The https protocol uses certificate based authentication and encryption.

References

- Software Engineering 9 Edition Ian Sommerville
- Software Engineering 9 Edition Ian Sommerville